

Watlington CP School, Audit Report**Audit Date: 4 March 2020****Report: Year 2 visit 1****DPE: Linda Mortimer****School members****Headteacher: Ruth McGlone**

1. Visit details

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed but could not be demonstrated to the school as unable to access Knowledge Bank fully. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 6 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 5.1 below).

Review actions recommended at time of previous visit – 27.9.19 (JE)

Action recommendations made within the walk and within the best practice information have been completed and these include:

Signposting to Privacy Notice: Visitors are now signposted to the location of the school's Privacy Notice in the Safeguarding leaflet which is handed out to all visitors.

HT Office & Physical Security: School now has new fire rated doors in H/T, Front Door and Office.

Displays: First name only on the Wow display board and student images have been removed from the Achievement book.

Laptops/USB sticks/portable devices: ICT Solutions Tech has checked and all devices are encrypted and password protected.

IT Audit & Data Cleansing: The IT Technician has worked with the Headteacher reviewed information held on the server and a data cleanse has taken place in September 2019.

Clear Desk Policy: This has been adopted by the school and has staff buy in.

Data audit/ Archiving/Destruction of Data: This has been reviewed and carried out. This practice will be embedded in the management of the school.

Secure Printing: The school operates with printing to a 'User Box' and this is used for printing sensitive / confidential documents.

Main office PC monitor: has been repositioned to obscure the view.

Naming Convention: First names only are used in class lists, coat pegs, displays, files, exercise books across the school.

Staff room: Student Care Plans have been removed from wall and now placed securely in folders.

Recommendations and Findings from Audit on 4 March 2020

CCTV: CCTV is now in place and there is adequate signage throughout the site.

The school has a CCTV policy in place and will use DPE logbook in event of application to view.

The CCTV hard disk is located in the server room and is in a dedicated locked cabinet.

Recordings are held in the Cloud and the Headteacher can access via her laptop using her school's IP address. The school secretary can access recordings via her desktop.

Visitor Signing in: The school is now using SG carbonless secure sign in system.

GDPR Policy: The policy published on the school's website is dated 28.9.17 and notes that the DPO is a bought in service from NCC.

Action: Amend to Data Protection Education as the DPO.

Privacy Notice: The Privacy Notice states that GDPR is the DPO. Provide a more detailed list of third parties with whom the school shares PII data. DPE will provide an example list of third parties.

Action: Amend to Data Protection Education as the DPO. Create a more detailed list of third parties in a separate appendices as this will make easier editing in the future.

Best Practice Checklists: The school experienced problems when trying to view Best Practice Checklists and when updating the checklists, they did not save. Google Chrome and Windows Explorer were both used to access KB, but without success.

Action: DPE will log this problem and a member of the DPE team will contact the school.

Staff Training: The majority of staff have completed GDPR 101 online training. DPE suggest that all staff should refresh their general GDPR training every 2 years. A 20-minute GDPR refresher will be available on Knowledge Bank in the near future. There are several bite-size training modules now available on Knowledge Bank. DPE suggest that staff complete the Password online training.

Breach and SAR Procedure and using DPE Online Log: The school will use the DPE online logs when they can access on Knowledge Bank.

Action: All staff should be aware of the Breach procedure and this can be shared via the Compliance Manager on KB. Relevant staff ie the Leadership Team and senior admin staff should be aware of the SAR procedure and this can be shared via Compliance Manager.

Other GDPR Policies: To date the Records Management Policy, Information Classification Policy and Freedom Information Policy have not been adopted by the school.

Action: The school will download the DPE model policies and present to the Governing Body in Summer Term 2020 for ratification. Once agreed, the policies should be published on the school's website.

Freedom of Information Publication Scheme: This scheme should be published on the school's website.

Action: School to review the example provided by DPE and amend to their own requirements. Further information about this scheme can be found under the 'News' tab on Knowledge Bank.

Clear Desk and Screen Policy: This policy has been adopted by the school and shared with staff.

Working Away from School : This policy has been adopted by the school and shared with staff.

Consent Forms: The school has checked their consent form against DPE model consent form.

Document Retention: The school is introducing a robust programme for review and safe destruction of out of date documents.

Action: DPE will send the 2016 IRMS Toolkit.

Management of Safeguarding & SEND Documents: Hard copies are retained in locked cabinet in Headteachers office and accessed by the DSLs. SEND documents are retained securely and have limited access.

Management of Student Assessment: The school uses hard copies for assessment which are retained securely.

Management of Communication with Parent: The school uses RM Integris which links with Parent Hub to provide text and email communication with parents. The school uses Teachers to Parents to provide a booking system for parent's evenings time slots.

Data Protection Impact Assessment: The school has used the NCC Business Impact Analysis form when considering any change to management processes.

Action: DPE will provide the ICO's standard template for DPIA.

Website Management: The school has embedded good practice to remove old out of date photos and information. DPE recommends that no more than 12 months newsletters are kept on the website at any one time.

Technical Security: School to request IT Technician to complete the Cyber Questionnaire as this will be used when populating the Record of Processing tool.

Action: IT Technician will be asked to complete Cyber Questionnaire.

School Kitchen: Operated by Norse. All allergy information is kept securely.

First Aid Records: Completed First Aid records are retained in locked room. Records relating to first aid administered to staff or where hospital visit is required, is recorded OSHENS.

Medical Student Care Plans: Are stored securely in locked cupboard.

GDPR Self-Auditing: The Headteacher accompanied by the Chair of Governors carries out a GDPR walk and findings are reported back to staff.

Staffroom: Pigeonholes were checked and the following was found:

- SEND request for paperwork detailing the student's full name
- Individual Education Plan IEP
- List detailing student's full names, also swimming list with the same level of detail

Action: Remind staff of the serious data breach risks relating to such practices especially paperwork relating to special category data ie SEND and IEP.

School Office: List on wall detailing students with unauthorized absence and awaiting medical evidence. The list included both names.

Action: Place in a folder and ensure stored securely when not in use

Year 3 Classroom: List on wall detailing students taking part in sporting activities. The list included both names.

Action: Remove surname or store securely.

Year 4 Classroom: Student's IEP easily accessible in open area – **this should be stored securely at all times.** Reading record books, Spellings and Salford Reading Tests were easily accessible. These included both names. Exercise books displaying both names.

Action: Headteacher to consider whether this member of staff should revisit GDPR 101 training.

IEPs should be stored securely. Completed reading tests and assessment documents should be stored securely. Exercise books should use first name only.

2. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: [https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016 IRMS Toolkit for Schools v5 Master.pdf](https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016%20IRMS%20Toolkit%20for%20Schools%20v5%20Master.pdf)
- DfE toolkit
[https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data Protection Toolkit for Schools OpenBeta.pdf](https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf) (Annex 5,1)

2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

5. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>